

شركة دايموند لوساطة التأمين
سياسة أمن أنظمة تقنية المعلومات
مايو 2025



Internal

DO NOT COPY

الاسم المسجل : شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي : طريق الثمامة , الربيع , الرياض
مسؤول المستند : مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بشركة الوثيقة الماسية (دايموند) ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



معلومات السياسة				
سياسة أمن أنظمة تقنية المعلومات			عنوان السياسة	
مُستحدثة			حالة السياسة	
لا يوجد			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
1ITM0004			رقم المستند	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
إدارة تقنية المعلومات			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الأسم	الوظيفة	الإدارة
	29/07/2025	تركي عبدالله العبدلي	مدير إدارة الإلتزام والامتثال	الإدارة الرقابية
	29/07/2025	شادن سلطان العتبي	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	29/07/2025	بدر سعد الشايح	العضو المنتدب	الإدارة العليا



إدارة الجودة والتطوير
Quality & Development Management

1. المقدمة:

1.1 تُعد سياسة أمن أنظمة تقنية المعلومات جزءاً أساسياً في البنية التحتية الحيوية التي تعتمد عليها جميع العمليات التشغيلية والإدارية لضمان حماية هذه الأصول من التهديدات السيبرانية والمخاطر التشغيلية، والامتثال للمتطلبات التنظيمية المعتمدة في المملكة العربية السعودية.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "دايموند") في أن الهدف من هذه السياسة هو وضع إطار تنظيمي شامل لضمان أمن وسلامة أنظمة تقنية المعلومات، وتحديد الضوابط الواجب الالتزام بها لتأمين الأنظمة والبنية التحتية الرقمية من الاختراقات أو إساءة الاستخدام. كما تهدف إلى:

2.1.1 منع الوصول غير المصرح به إلى الأنظمة.

2.1.2 حماية البيانات أثناء التخزين والنقل والتشغيل.

2.1.3 تطبيق ضوابط الأمان على الشبكات، البيئات، والأجهزة الطرفية.

2.1.4 ضمان الجاهزية للاستجابة للحوادث.

2.1.5 تعزيز الالتزام التنظيمي.

3. التعاريف:

3.1 دايموند: شركة الوثيقة الماسية لوساطة التأمين.

3.2 أنظمة تقنية المعلومات: كافة البرمجيات، الخوادم، قواعد البيانات، أنظمة التشغيل، الأنظمة السحابية، وأنظمة التحكم المؤسسية التي تُستخدم في تشغيل وإدارة البنية التحتية الرقمية في الشركة.

3.3 الأنظمة الحساسة: الأنظمة التي تحتوي على بيانات مالية، صحية، شخصية، أو سرية تخص العملاء أو العمليات التشغيلية الداخلية.

3.4 البيانات الحساسة: بيانات تحتوي على معلومات شخصية أو مالية أو طبية أو تعاقدية تُعرف أو تخص فرداً أو جهة، وتتطلب حماية خاصة بموجب السياسات التنظيمية.

3.5 بيئات الأنظمة: بيئة التطوير (DEV)، بيئة الاختبار (UAT)، بيئة الإنتاج (PROD)، وكل منها تُستخدم في مراحل مختلفة من دورة حياة الأنظمة.

3.6 Access Point: نقطة الاتصال اللاسلكية التي تتيح الربط بشبكة Wi-Fi داخل المنشأة.

3.7 CVSS (Common Vulnerability Scoring System): نظام عالمي لتصنيف خطورة الثغرات الأمنية.

3.8 DLP (Data Loss Prevention): آلية منع تسرب البيانات، تُستخدم لمراقبة البيانات الحساسة ومنع تصديرها خارج النظام.

3.9 EDR (Endpoint Detection and Response): نظام متقدم للكشف والاستجابة على الأجهزة الطرفية.

3.10 FIM (File Integrity Monitoring): أداة تراقب التعديلات على ملفات النظام الحيوية وتنبه عند التغييرات غير المصرح بها.

3.11 IDS (Intrusion Detection System): نظام كشف التسلل، يُستخدم لرصد الأنشطة غير المصرح بها داخل الشبكة.

3.12 MFA (Multi-Factor Authentication): المصادقة متعددة العوامل، أسلوب حماية يتطلب أكثر من وسيلة تحقق قبل السماح بالدخول.

3.13 RFC (Request for Change): تذكرة تغيير معتمدة تُستخدم لتنظيم وتنفيذ التحديثات البرمجية أو التشغيلية.

3.14 SIEM (Security Information and Event Management): نظام مركزي لتحليل وتجميع الأحداث الأمنية، يساعد في مراقبة الأنظمة واكتشاف التهديدات.

3.15 Tamper Protection: ميزة تمنع التعديل أو إيقاف برامج الحماية على الأجهزة.

3.16 التصعيد الفني: إجراء يُتخذ عند ظهور مشكلة تقنية حرجية، يتضمن رفع الحالة إلى مستوى إداري أعلى لاتخاذ قرار فوري.

3.17 الجهة المالكة للنظام: الإدارة التي تستخدم الأنظمة التقنية بشكل رئيسي وتكون مسؤولة وظيفياً عن تشغيلها، اعتماد التحديثات المقترحة، مراجعة صلاحيات المستخدمين، والتنسيق مع إدارة تقنية المعلومات لضمان الامتثال والتكامل التشغيلي.

3.18 سجل الأجهزة: قاعدة بيانات رسمية تحتوي على كافة معلومات الأجهزة المستخدمة، تُستخدم لأغراض التتبع والمراقبة.

3.19 سجل الحوادث التقنية: سجل إلكتروني أو ورقي يُوثق جميع الحوادث المرتبطة بأمن المعلومات أو الأعطال التشغيلية.

3.20 مشرف تقنية المعلومات: الموظف المسؤول عن إدارة البنية التحتية التقنية، إعداد الشبكات، ضبط الأجهزة، تنفيذ السياسات الفنية، والتنسيق مع الإدارات الأخرى.

3.21 مسؤول الأمن السيبراني: الموظف المسؤول عن مراقبة ضوابط الأمن السيبراني، تحليل السجلات، اكتشاف الثغرات، وتنسيق الاستجابة للحوادث.

- 3.22 مبدأ أقل صلاحية (Least Privilege): مبدأ أمني ينص على منح المستخدمين أقل قدر من الصلاحيات المطلوبة لأداء مهامهم فقط.
- 3.23 نظام إدارة الأصول: نظام إلكتروني لتوثيق ومتابعة أصول تقنية المعلومات (أجهزة، برمجيات، شبكات)، يُحدث دوريًا.
- 3.24 تقرير تحليل الحادث: وثيقة تُعد من قبل مسؤول الأمن السيبراني بعد وقوع حادث، تتضمن تحليل الأسباب، نطاق الأثر، والتوصيات التصحيحية. (يستمر باقي المحتوى كما هو دون تغيير).

4. نطاق تطبيق السياسة:

4.1 تُطبق هذه السياسة على جميع أنظمة تقنية المعلومات التابعة للشركة بما يشمل:

- 4.1.1 الخوادم المحلية والسحابية.
- 4.1.2 أجهزة الشبكات .
- 4.1.3 أنظمة البريد الإلكتروني، الاتصال، والوصول.
- 4.1.4 بيئات التشغيل والتطوير.
- 4.1.5 أجهزة الموظفين المرتبطة بالشبكة.

5. القطاعات والإدارات ذات العلاقة:

5.1 إدارة تقنية المعلومات. قسم الأمن السيبراني.

6. الكيانات ذات العلاقة:

- 6.1 كافة الكيانات المملوكة بالكامل إلى شركة داي몬드.
- 6.2 المزودون التقنيون المعتمدون.
- 6.3 الجهات الرقابية (هيئة التأمين، هيئة الأمن السيبراني)



إدارة الجودة والتطوير Quality & Development Management

7. قواعد عامة:

7.1 التكوين الآمن للأنظمة:

- 7.1.1 يجب على إخصائي تقنية المعلومات في إدارة تقنية المعلومات تجهيز جميع الأنظمة التشغيلية وفق تكوينات أمنية معتمدة، وتحديثها بشكل دوري كل 3 أشهر.
- 7.1.2 يُلزم بحذف جميع الحسابات والإعدادات الافتراضية فور تثبيت النظام، بما في ذلك كلمات المرور العامة أو حسابات الضيف.
- 7.1.3 يجب تعطيل جميع الخدمات والمنافذ التي لا تستخدم فعليًا في بيئة الإنتاج، بعد مراجعة فنية معتمدة.
- 7.1.4 تُوثق التكوينات في سجل مشفر ضمن نظام إدارة الأصول التقنية، ويُراجع هذا السجل من قبل مسؤول الأمن السيبراني بشكل ربع سنوي.
- 7.1.5 في حال رصد أي انحراف في التكوينات، يُلزم الفريق التقني بتصحيحه خلال يومي عمل وإعداد تقرير متابعة.

7.2 التحكم في الوصول:

- 7.2.1 يجب أن يُطبق مبدأ "أقل صلاحية" (Least Privilege) لجميع المستخدمين على الأنظمة والتطبيقات.
- 7.2.2 يُمنع منعًا باتًا استخدام حسابات مشتركة أو مشاركة بيانات الدخول بين الموظفين.
- 7.2.3 يجب تفعيل المصادقة متعددة العوامل (MFA) في كل نظام يحتوي على بيانات مالية أو شخصية أو حساسة.
- 7.2.4 تُراجع صلاحيات الدخول كل 3 أشهر من قبل مسؤول نظام الوصول (مشرف تقنية المعلومات)، مع مصادقة النتائج من الجهة المالكة للنظام.
- 7.2.5 في حال اكتشاف صلاحيات زائدة، تُزال مباشرة، وتُوثق الحادثة في سجل الوصول ويُعرض على مشرف تقنية المعلومات.

7.3 الفصل بين البيئات:

- 7.3.1 يجب إنشاء ثلاث بيئات منفصلة: تطوير (DEV)، اختبار (UAT)، وإنتاج (PROD) مع منع مشاركة قواعد البيانات الحقيقية خارج بيئة الإنتاج.
- 7.3.2 يُلزم بتوثيق كل عملية نقل أو ترقية كود بين البيئات، ويتم اعتمادها من مسؤول التغيير.
- 7.3.3 يُمنع على فريق التطوير امتلاك صلاحية مباشرة على بيئة الإنتاج، ويُسمح فقط بقراءة محدودة إن لزم.
- 7.3.4 تُجرى مراجعة فصل البيئات نصف سنويًا.

7.4 أمن الشبكات والبنية التحتية:

- 7.4.1 يجب تطبيق ضوابط جدران الحماية (Firewall Rules) بما يضمن تقليل المنافذ المفتوحة إلى الحد الأدنى.
- 7.4.2 تُفعل أنظمة كشف التسلل (IDS) وأنظمة إدارة السجلات (SIEM) وتُراقب 24/7 من قبل فريق الأمن السيبراني.
- 7.4.3 يجب تحديث مخطط الشبكة وتوثيقه كل 6 أشهر على الأقل، ومراجعته من مدير الشبكات.
- 7.4.4 يُمنع استخدام أي بروتوكولات ضعيفة (مثل Telnet، FTP)، ويجب الاعتماد فقط على بروتوكولات مؤمنة مثل SSH، HTTPS.
- 7.4.5 أي محاولة ربط شبكة داخلية بشبكة خارجية تتطلب إذنًا مكتوبًا من الإدارة التقنية، ويجب تسجيلها في سجل الاتصالات الشبكية.
- 7.4.6 في حال رصدت محاولة غير مصرح بها لربط الشبكة، يجب على مسؤول الأمن السيبراني إصدار تنبيه فوري، وإبلاغ مشرف تقنية المعلومات خلال ساعة واحدة، وتوثيق الحادثة في سجل الحوادث، على أن تُعرض لاحقًا على لجنة الأمن للمراجعة.
- 7.4.7 يُمنع توصيل أو استخدام أجهزة مثل مبدلات الشبكة أو نقاط الاتصال دون اعتماد رسمي وتوثيق كامل في نظام الأصول.

7.5 التحديثات وإدارة الثغرات:

- 7.5.1 يُلزم بفحص أنظمة التشغيل وقواعد البيانات شهريًا باستخدام أدوات معتمدة (مثل Nessus، Qualys).
- 7.5.2 يجب تطبيق التحديثات الحرجة خلال 24 ساعة، والتحديثات المتوسطة خلال أسبوع.
- 7.5.3 يُمنع تنفيذ أي تحديث في الإنتاج دون وجود تذكير تغيير (RFC) موقعة حسب سياسة التغيير.
- 7.5.4 تُصنف الثغرات حسب إطار CVSS، وتُخصص أولوية زمنية محددة لكل تصنيف.
- 7.5.5 تُراجع نتائج الفحوصات الدورية في اجتماع شهري ويُحدث سجل الثغرات بناءً عليها.
- 7.5.6 اختبار الاختراق (Penetration Testing):

- 7.5.6.1 يجب إجراء اختبار اختراق داخلي وخارجي وتطبيقات الاستضافة على الأقل مرة واحدة سنويًا، أو بعد أي تغيير جوهري

في البيئة التقنية (مثل ترقية البنية التحتية أو إطلاق نظام جديد).

- 7.5.6.2 تُنفذ الاختبارات من قبل جهة متخصصة مستقلة أو فريق داخلي معتمد، وتوثق النتائج بالكامل.

- 7.5.6.3 يجب معالجة جميع الثغرات القابلة للاستغلال التي يتم اكتشافها خلال الاختبار خلال فترة لا تتجاوز 30 يومًا، ويُعاد اختبارها بعد المعالجة للتحقق من الإغلاق.
- 7.5.6.4 تُحفظ تقارير اختبار الاختراق ضمن سجل الثغرات، وتُعرض في تقرير شهري لأمن المعلومات.
- 7.5.7 الفحص الدوري للثغرات (Vulnerability Scanning):
- 7.5.7.1 يجب إجراء فحص دوري لاكتشاف الثغرات الأمنية في الشبكات الداخلية والخارجية مرة واحدة على الأقل كل 3 أشهر، أو فور أي تعديل جوهري في الشبكة.
- 7.5.7.2 تُستخدم أدوات فحص معتمدة مثل Nessus أو Qualys أو ما يعادلها، ويجب أن يشمل الفحص الخوادم، الأجهزة، والأنظمة الحيوية.
- 7.5.7.3 يجب معالجة جميع الثغرات المصنفة "حرجة (Critical)" أو "عالية (High)" خلال فترة لا تتجاوز 14 يومًا، ويُعاد الفحص حتى التأكد من زوالها.
- 7.5.7.4 في حال اكتشاف دليل على اختراق فعلي أو استغلال لأحد الموارد، يُلزم بالإبلاغ الفوري إلى مسؤول الأمن السيبراني وفريق الدعم الفني، مع توثيق الحدث كحادثة أمنية رسمية.
- 7.5.8 تحديث معايير التكوين الأمنية (Security Baseline Updates):
- 7.5.8.1 يجب تحديث معايير التكوين الأساسية (Baseline Configurations) لجميع الأنظمة والخوادم عند ظهور ثغرات جديدة تؤثر على إعداداتها.
- 7.5.8.2 يُلزم الفريق التقني بمراجعة الإعدادات القديمة وتعديلها بما يتماشى مع أحدث توصيات الأمن السيبراني، بالتنسيق مع مسؤول الأمن السيبراني.
- 7.5.8.3 تُوثق جميع التحديثات على خطوط الأساس الأمنية في سجل مستقل يُراجع نصف سنويًا.
- 7.5.9 التحقق من تطبيق التحديثات:
- 7.5.9.1 يجب التحقق من نجاح تطبيق التحديثات الأمنية خلال فترة لا تتجاوز 5 أيام من التنبيه.
- 7.5.9.2 تُستخدم أدوات مراقبة تلقائية لتأكيد اكتمال التطبيق، ويجب تسجيل نتائج التحقق ضمن سجل التحديثات.
- 7.5.9.3 في حال فشل التحديث أو عدم نجاح التنبيه، يُعاد الجدولة فورًا ويُعد تقرير متابعة لفريق تقنية المعلومات.
- 7.6 الحماية من البرمجيات الخبيثة:
- 7.6.1 يجب تثبيت برنامج مكافحة الفيروسات المعتمد Centrally Managed Anti-Malware Solution (مثل Kaspersky Endpoint Security أو Microsoft Defender for Endpoint) على جميع الأجهزة في الشركة، بما في ذلك الحواسيب والخوادم وأجهزة المستخدمين.
- 7.6.2 يُلزم بتحديث قاعدة بيانات الفيروسات تلقائيًا بشكل يومي من خلال خادم الحماية المركزي، وتُراجع تقارير التحديث من قبل مسؤول الأمن السيبراني أسبوعيًا.
- 7.6.3 يُمنع على المستخدمين إيقاف برنامج الحماية أو تعديله بأي شكل، ويجب تفعيل خاصية الحماية من العبث (Tamper Protection) لضمان ذلك.
- 7.6.4 تُفحص جميع وسائط التخزين الخارجية (مثل USB و DVD) عبر برنامج الفحص المعتمد قبل استخدامها، ولا يُسمح باستخدامها دون تصريح خطي من مدير تقنية المعلومات.
- 7.6.5 تُستخدم أدوات تصفية المحتوى الإلكتروني ومنع الوصول إلى المواقع الضارة (مثل Web Filtering أو DNS Filtering Gateways)، وتُحدث قوائم الحظر كل 12 ساعة تلقائيًا.
- 7.6.6 يجب الاحتفاظ بسجل فحص البرمجيات الخبيثة لكل جهاز لمدة لا تقل عن 6 أشهر، ويُراجع هذا السجل شهريًا من قبل مسؤول الأمن السيبراني لاكتشاف أنماط التهديدات المحتملة.
- 7.7 إدارة السجلات والأنشطة:
- 7.7.1 يجب تفعيل التسجيل الكامل لجميع الأنشطة، بما يشمل الدخول، التعديلات، الفشل، والتصعيد.
- 7.7.2 تُرسل السجلات إلى منصة مركزية (مثل Splunk أو Wazuh)، وتُحتفظ بها لمدة سنة على الأقل.
- 7.7.3 تُراجع السجلات أسبوعيًا من قبل مسؤول الأمن السيبراني وتُعد تقارير بالحالات المريبة.
- 7.7.4 تُفعل أدوات تتبع التغيير مثل File Integrity Monitoring (FIM) في أنظمة التشغيل الحيوية.
- 7.7.5 في حال وجود محاولة تعديل غير مصرحة، يُبلغ عنها فورًا وتُعالج خلال 24 ساعة.
- 7.8 حماية البيانات أثناء التشغيل والتخزين والنقل:

- 7.8.1 تُشفّر جميع البيانات المصنفة "سرية" باستخدام AES-256 في قواعد البيانات وأنظمة الملفات.
- 7.8.2 يُستخدم HTTPS في المواقع الداخلية والخارجية وSFTP في النقل بين الخوادم.
- 7.8.3 يُمنع نقل أي ملف حساس عبر البريد الإلكتروني ما لم يُشفّر باستخدام PGP أو ما يعادله.
- 7.8.4 تُحدث سياسات التصنيف كل 6 أشهر بالتعاون مع إدارة الامتثال.
- 7.8.5 تُسجل كل عملية نقل بيانات في سجل خاص يُراجع دوريًا.
- 7.9 6.9 الهيئة الآمنة للأجهزة الطرفية
- 7.9.1 يجب إغلاق جميع منافذ USB افتراضيًا، ويُمنح الاستثناء فقط بموجب طلب موثق ومعتمد من مدير تقنية المعلومات.
- 7.9.2 تُستخدم أدوات التحكم في الأجهزة (Device Control) لمراقبة إدخال أو إخراج البيانات.
- 7.9.3 تُفعل حلول EDR (مثل CrowdStrike) في جميع الأجهزة، وتُربط بلوحة تحكم مركزية لدى فريق الأمن السيبراني.
- 7.9.4 يجب أن يخضع كل جهاز لعملية تحديث وإعادة تهيئة عند انتقاله من مستخدم إلى آخر، وتتم العملية وفق الخطوات التالية:
- 7.9.4.1 يقوم المستخدم السابق بإعادة الجهاز إلى مشرف تقنية المعلومات.
- 7.9.4.2 يقوم الفريق بإجراء مسح كامل للبيانات وفق آلية الحذف الآمن.
- 7.9.4.3 يُعاد تثبيت نظام التشغيل وتطبيق السياسات الأمنية.
- 7.9.4.4 يُسجل الجهاز مجددًا باسم المستخدم الجديد في سجل الأجهزة.
- 7.9.5 تُنفذ هذه العملية من قبل مشرف تقنية المعلومات في إدارة تقنية المعلومات، ويجب توثيق كل عملية نقل أو تهيئة في سجل الأجهزة.
- 7.9.6 في حال فقدان جهاز، يجب تنفيذ المسح عن بُعد خلال ساعتين من البلاغ وتوثيق الإجراء في سجل الحوادث التقنية.
- 7.10 المراقبة والاستجابة للحوادث:
- 7.10.1 يجب تشغيل أدوات SIEM لتوليد التنبيهات التلقائية عند رصد أي سلوك غير اعتيادي.
- 7.10.2 تُدار الحوادث وفق جدول استجابة محدد في سياسة الحوادث، ويُبلغ عنها في خلال ساعة واحدة.
- 7.10.3 يجب أن تُخزن الأدلة الإلكترونية (Logs، صور الشاشة، التقارير) في وحدة تخزين مقيدة الصلاحيات.
- 7.10.4 يُعد تقرير تحليل أولي خلال 48 ساعة، ويرفع لمدير الأمن السيبراني ثم الإدارة العليا.
- 7.10.5 تُناقش الحالات شهريًا في اجتماع مخاطر الأمن المعلوماتي.
- 7.11 أمن الاتصالات اللاسلكية:
- 7.11.1 يجب تسجيل واعتماد كل نقطة اتصال (Access Point) في سجل الشبكة اللاسلكية.
- 7.11.2 تُستخدم WPA3 أو أعلى عند توفرها، مع تعطيل بث اسم الشبكة (SSID) متى ما أمكن.
- 7.11.3 يُمنع تشغيل أي نقطة اتصال شخصية في مقر الشركة.
- 7.11.4 تُجرى عمليات تفتيش ربع سنوية بحثًا عن أجهزة بث لاسلكية غير مصرح بها (Rogue APs).
- 7.12 ضوابط الوصول الفيزيائي:
- 7.12.1 يُلزم بتأمين جميع المواقع الحساسة ببطاقات مغنطة وأنظمة مراقبة فيديو.
- 7.12.2 يجب تفعيل سجل دخول الزوار وتوثيق هوية كل زائر ومكان وجهته ومدة مكوثه.
- 7.12.3 يُراجع نظام الصلاحيات الفيزيائية شهريًا، وتُلغى صلاحيات الموظف خلال 24 ساعة من ترك العمل.
- 7.12.4 يُمنع تخزين أي معدات تقنية في بيئات مفتوحة بدون قفل أو مراقبة كاميرات.
- 7.13 صلاحيات بطاقات الدخول:
- 7.13.1 تُمنح بطاقات الدخول فقط بموافقة مشرف تقنية المعلومات أو لجنة الأمن الفيزيائي.
- 7.13.2 يجب توقيع الموظف على نموذج إقرار بالدخول وسرية المعلومات قبل تفعيل البطاقة.
- 7.13.3 يُمنع مشاركة البطاقات أو إعارتها.
- 7.13.4 تُسحب الصلاحية مباشرة عند الاستقالة أو الانتقال لإدارة أخرى.
- 7.13.5 يُراجع سجل البطاقات كل 3 أشهر وتُلغى غير الضرورية.
- 7.14 مراقبة الزوار:
- 7.14.1 يُشترط وجود مرافق مع الزائر في كل المناطق الخاضعة للرقابة.
- 7.14.2 لا يُسمح للزوار بالتحرك داخل المواقع الحساسة دون تصريح ومرافقة.

7.15 أحكام الأمن الفيزيائي:

- 7.15.1 يجب توقيع جميع الموظفين المصرح لهم بالدخول الفيزيائي إلى مرافق المعلومات على نماذج إقرار الدخول والسرية.
- 7.15.2 يُمنع استخدام بطاقة أو مفتاح دخول من قبل أي شخص آخر خلاف صاحبها، كما يُمنع إعارتها أو مشاركتها.
- 7.15.3 يجب الإبلاغ فوراً عن فقدان أو سرقة بطاقات أو مفاتيح الدخول إلى مشرف تقنية المعلومات، ويجب إلغاء صلاحيتها فوراً.
- 7.15.4 تُراجع صلاحيات بطاقات ومفاتيح الدخول كل 3 أشهر، وتُلغى من لا تتطلب مهامهم استمرار الوصول.
- 7.15.5 يُمنع إعادة تخصيص أي بطاقة دخول لشخص آخر قبل إنهاء إجراءات الإرجاع الرسمية وتوثيقها.
- 7.15.6 يُشترط مرافقة جميع الزوار من قبل موظف مخوّل أثناء تواجدهم داخل المناطق المحمية أو الحساسة.
- 7.15.7 يُمنع نشر أو تداول أي خرائط أو دلائل داخلية تُظهر مواقع أنظمة أو بيانات حساسة.
- 7.15.8 يجب اتخاذ تدابير لحماية أنظمة المعلومات من انقطاعات الكهرباء أو الأعطال في البنية التحتية، مثل توفير مصادر طاقة احتياطية.
- 7.15.9 تُراقب الظروف البيئية (درجة الحرارة والرطوبة) في غرف الخوادم والمرافق الحساسة للتأكد من توافقها مع متطلبات التشغيل الآمن.

7.16 تصنيف وإدارة المعلومات وتطبيقها في الأنظمة:

- 7.16.1 يجب أن تطبق الأنظمة قواعد التحكم في الوصول استناداً إلى التصنيفات التالية:
- 7.16.1.1 عام (Public): معلومات لا تتطلب حماية خاصة ويجوز مشاركتها علناً.
- 7.16.1.2 داخلي (Internal): معلومات يجب حمايتها لأسباب مهنية أو تنظيمية، ولا تُشارك إلا مع موظفين مفوضين.
- 7.16.1.3 سري (Confidential): معلومات حساسة محمية نظامياً أو عقدياً، ويقتصر الاطلاع عليها على من لديهم حاجة وظيفية (Need-to-know).
- 7.16.1.4 حساس جداً (Highly Confidential): مستوى إضافي يستخدم عند الحاجة الماسة لحماية معلومات شديدة الحساسية (كأسرار العملاء أو البيانات النظامية المحمية).
- 7.16.2 دعم الأنظمة للتصنيف:
- 7.16.2.1 تُمنع البرمجيات أو الأنظمة التي لا تدعم تطبيق سياسات التصنيف من الدخول في بيئة الإنتاج. ويُشترط توافقها مع معايير الحماية المدمجة (مثل RBAC، DLP).
- 7.16.2.2 7.16.2.3 التحكم في الوصول التلقائي
- 7.16.2.3 عند تغيير تصنيف أي معلومة أو ملف، يُحدث النظام تلقائياً مستوى الحماية بناءً على قواعد الحماية المعتمدة.
- 7.16.3 التوثيق والتغيير:
- 7.16.3.1 يجب توثيق كل عملية تغيير في التصنيف من خلال سجل إلكتروني يُحدث تلقائياً أو يدوياً من قبل مسؤول النظام، ويُشترط تقديم طلب مبرر مع اعتماد من مسؤول الأمن السيبراني.
- 7.16.4 حماية المعلومات حسب التصنيف:
- 7.16.4.1 الداخلية: تُخزن في بيئات مغلقة (مكاتب مغلقة أو أنظمة داخلية) ويُشترط توقيع اتفاقيات سرية للوصول إليها.
- 7.16.4.2 السرية: تُشفّر أثناء التخزين (at rest) والنقل، ويُمنع إرسالها عبر قنوات غير مؤمنة مثل البريد غير المشفر أو الرسائل الفورية.
- 7.16.4.3 الحساسية جداً: تُخزن في بيئات محكمة الدخول (خزائن مغلقة، غرف محمية بكروت مغنطة)، وتُطبق عليها ضوابط مشددة تشمل تسجيل الدخول، التشفير، وتحديد الصلاحيات الدقيقة.
- 7.16.5 التنبيه والاستجابة:
- 7.16.5.1 تُراجع محاولات اختراق البيانات المصنفة بشكل دوري، وتُبلغ فوراً إلى وحدة الاستجابة للحوادث لاتخاذ الإجراءات اللازمة. كما يجب إبلاغ الإدارة العليا في حال الاشتباه بتسريب أي معلومات سرية.
- 7.16.6 المسؤوليات:
- 7.16.6.1 مستخدم المعلومات: يلتزم بالاستخدام النظامي للمعلومة حسب التصنيف.
- 7.16.6.2 مالك المعلومات: يحدد التصنيف، ويُعتمد منه أي تغيير، ويتحمل مسؤولية مشاركة التصنيف مع الأطراف الأخرى.
- 7.16.6.3 حارس المعلومات: (عادةً من موظفي تقنية المعلومات) يطبق آليات الحماية والتشفير حسب التصنيف المحدد.
- 7.16.7 الاحتفاظ والإتلاف:
- 7.16.7.1 تُخزن المعلومات وفق جدول الحفظ الرسمي المعتمد في الشركة.

7.16.7.2 عند انتهاء الحاجة للمعلومة، تُصنف كـ "منتهية" ويتم إتلافها باستخدام آلية معتمدة (حذف آمن / تمزيق ورقي / مسح مشفر).

7.16.7.3 لا يُسمح بإتلاف أي معلومة إلا بعد الرجوع إلى مالكيها لتأكيد عدم الحاجة للتمديد.

7.17 استعادة الكوارث واستمرارية الأعمال:

7.17.1 يجب على شركة داييموند لوساطة التأمين إعداد وتنفيذ خطة رسمية لاستعادة الكوارث واستمرارية الأعمال (Disaster Recovery & Business Continuity Plan - DRP)، تهدف إلى ضمان استعادة الأنظمة الحيوية والبيانات الأساسية في حال حدوث انقطاع أو كارثة تقنية أو تشغيلية.

7.17.2 يلتزم فريق تقنية المعلومات، بالتنسيق مع لجنة أمن المعلومات، بتحديث وتوثيق خطة الاستعادة بشكل سنوي على الأقل، وإجراء اختبارات دورية لها، وتحليل نتائج الاختبارات لاتخاذ إجراءات تصحيحية وتحسينية فورية.

7.17.3 يجب أن تتضمن خطة الاستعادة، كحد أدنى، العناصر التالية:

7.17.3.1 تحليل الأثر على الأعمال (Business Impact Analysis - BIA) يشمل تقييم المخاطر، وتصنيف الأصول التقنية حسب حساسيتها وأهميتها التشغيلية.

7.17.3.2 تعريف واضح للأنظمة الحيوية والمعلومات الأساسية التي تتطلب استعادة فورية.

7.17.3.3 استراتيجيات وقائية تشمل: أنظمة الطاقة غير المنقطعة (UPS)، مكافحة الحرائق، الحماية من تقلبات التيار، والتحكم البيئي في الحرارة والرطوبة والغبار.

7.17.3.4 إجراءات نسخ احتياطي منتظمة وتخزين آمن في مواقع خارجية متعددة (offsite).

7.17.3.5 خطة تشغيل بديلة (Contingency Plan) توضح آليات استعادة الأنظمة والبيانات خلال فترات التوقف.

7.17.3.6 تحديد المسؤوليات التنظيمية لكل إدارة وفريق خلال مراحل الكارثة (الاستجابة - الاستعادة - التشغيل المرحلي).

7.17.3.7 إجراءات تصعيد واضحة للإبلاغ عن الحوادث الكارثية، وتفعيل خطة الاستعادة، ومتابعة تنفيذها حتى الاستقرار الكامل.

7.17.4 يجب أن تشمل الخطة برامج تدريبية دورية لجميع الأفراد ذوي العلاقة، بالإضافة إلى تنفيذ محاكاة حقيقية لاختبار جاهزية الفرق، وتوثيق نتائج المحاكاة، وتضمينها في تقارير التحسين السنوية.

7.17.5 يلتزم جميع الموظفين المعنيين، والموردين الفنيين، بتنفيذ تعليمات خطة الاستعادة فور إعلان حالة الكارثة، كما يجب عليهم الامتثال التام للإجراءات المحددة دون تأخير أو اجتهاد فردي.

7.17.6 يُمنع التعامل الاترجالي أو تشغيل أي نظام حيوي متأثر قبل مراجعة خطة الاستعادة المعتمدة والحصول على إذن من مشرف تقنية المعلومات أو مسؤول أمن المعلومات.

7.17.7 يجب أن تُحفظ نسخة محدثة من خطة الاستعادة في موقعين منفصلين على الأقل (رقمي ومادي)، وأن تُتاح للجهات ذات العلاقة عند الحاجة، مع ضمان سريتها وعدم تداولها خارج النطاق المخول.

7.17.8 تُعد أي مخالفة لهذه السياسة، مثل التأخير في الاستجابة، أو الفشل في تنفيذ الإجراءات المحددة، أو الإهمال في تحديث الخطة، مخالفة جسيمة تُعرض مرتكبها للإجراءات التأديبية وفق أنظمة الشركة، وقد تشمل إنهاء الخدمة أو التبعات القانونية.

7.18 دورة تطوير واعتماد سياسة أمن أنظمة تقنية المعلومات:

7.18.1 يجب أن تمر سياسة أمن أنظمة تقنية المعلومات بمراحل تطوير واضحة تتضمن:

7.18.1.1 التطوير ← المراجعة ← الاعتماد ← التطبيق ← التقييم المستمر، وذلك لضمان توافرها مع احتياجات العمل والمستجدات التنظيمية.

7.18.2 يُلزم فريق تقنية المعلومات بتوثيق كل مرحلة ضمن سجل دورة حياة السياسات الأمنية، مع تحديد الجهة المنفذة والتاريخ.

7.19 إشراف لجنة الأمن السيبراني:

7.19.1 يجب أن تُعرض السياسة على لجنة الأمن السيبراني بشركة داييموند (DIB Information Security Committee) لمراجعتها، والتأكد من توافرها مع برنامج أمن المعلومات الشامل.

7.19.2 يُلزم مسؤول الأمن السيبراني برفع أي تحديثات جوهرية إلى اللجنة، ولا تُعتمد السياسة إلا بموافقة موثقة من اللجنة.

7.19.3 تُحفظ جميع محاضر اعتماد السياسات ضمن سجل رسمي لدى إدارة تقنية المعلومات.

7.20 نشر السياسة والتوعية الوظيفية:

7.20.1 يجب على إدارة تقنية المعلومات نشر النسخة النهائية المعتمدة من هذه السياسة عبر البوابة الداخلية الرسمية للموظفين.

- 7.20.2 يُلزم كل موظف لديه صلاحيات دخول على أنظمة تقنية المعلومات بالتوقيع على إقرار بالاطلاع على هذه السياسة والالتزام بما ورد فيها.
- 7.20.3 تُنظم إدارة الأمن السيبراني دورات توعوية مرة سنوياً على الأقل، لتثقيف الموظفين بشأن بنود هذه السياسة، وشرح أبرز الضوابط والممارسات السليمة.
- 7.21 قياس الالتزام ومراجعة الامتثال:
- 7.21.1 يجب على مسؤول الأمن السيبراني إجراء مراجعات امتثال شهرية تشمل تحليل السجلات، مراجعة الصلاحيات، والتحقق من تنفيذ ضوابط الأمن.
- 7.21.2 تُعد تقارير تقييم امتثال أمن المعلومات بشكل ربع سنوي، تُرفع إلى الإدارة العليا ولجنة الأمن السيبراني مع التوصيات التصحيحية.
- 7.21.3 يُلزم كل قسم مالك لنظام تقني بالتعاون الكامل مع المراجعات والتقارير، وتوفير الوثائق والدعم المطلوب عند الطلب.

8. مسؤولية السياسة:

- 8.1 إدارة تقنية المعلومات:
- 8.1.1 مسؤولون عن تنفيذ التكوينات الأمنية، إدارة الشبكات، وإغلاق المنافذ والثغرات التشغيلية.
- 8.2 قسم الأمن السيبراني:
- 8.2.1 مسؤولون عن تحليل السجلات، مراقبة الدخول، فحص الثغرات، والاستجابة للحوادث الأمنية.
- 8.3 الإدارات المالكة للأنظمة:
- 8.3.1 مسؤولية عن الإبلاغ عن المشاكل الأمنية، والتعاون في تنفيذ إجراءات الحماية.
- 8.4 إدارة الجودة والتطوير:
- 8.4.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

- 9.1 الحاقاً لتعميم المواصفات الفنية لنظام المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (197/202010)، بتاريخ 27/10/2020.
- 9.2 استخدام نظام المراقبة الرقمي في النقل والحفظ الأمن لتسجيلات وبيانات أجهزة المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (224/202110)، بتاريخ 24/10/2021.
- 9.3 الدليل التنظيمي لأمن المعلومات، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (250/202205)، بتاريخ 26/05/2022.

10. حفظ السياسة:

- 10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.
- 10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقادم المستندات. ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

- 11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة داي몬드 المعتمدة.

Diamond Insurance Broker

IT Systems Security Policy

May 2025

Registered Name: Diamond Insurance Broker Company

Head Office: Al Thumama Road, Al Rabie District, Riyadh

Document Owner: Quality & Development Manager

Internal

DO NOT COPY



Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



إدارة الجودة والتطوير Quality & Development Management

Article (1): This document and the information it contains are related to Al Wathiq Al Massiya Insurance Broker (Diamond). They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

Policy Information				
Policy Title	IT Systems Security Policy			
Policy Status	Newly Issued			
Previous Policy Title	None			
Previous Policy Date	None			
Document Number	1ITM0004			
Next Review Date	Two years from the date of policy approval or as required			
Policy Owner	Information Technology Management			
Prepared by	Quality & Development Management			
Managements/Functions that Reviewed and Approved the Policy				
Management	Position	Name	Date	Signature
Regulatory Management	Legal and Compliance Manager	Turki Abdullah Al-Abdali	29/07/2025	
Policy Review Lead	Quality & Development Manager	Shaden Sultan Alotaibi	29/07/2025	
Policy Approval				
Senior Management	Managing Director	Badr Saad Al Shaya	29/07/2025	



إدارة الجودة والتطوير
Quality & Development Management

1. Introduction:

1.1 The Information Technology Systems Security Policy is a fundamental part of the vital infrastructure that supports all operational and administrative processes, ensuring the protection of these assets from cyber threats, operational risks, and compliance with the regulatory requirements approved in the Kingdom of Saudi Arabia.

2. Policy Objective:

2.1 Diamond Insurance Brokerage Company (hereinafter referred to as "Diamond") believes that the objective of this policy is to establish a comprehensive regulatory framework to ensure the security and integrity of IT systems, defining the controls required to secure the systems and digital infrastructure from breaches or misuse. The policy also aims to:

2.1.1 Prevent unauthorized access to systems.

2.1.2 Protect data during storage, transmission, and processing.

2.1.3 Implement security controls on networks, environments, and endpoints.

2.1.4 Ensure readiness to respond to incidents.

2.1.5 Enhance regulatory compliance.

3. Definitions:

3.1 Diamond: Diamond Insurance Brokerage Company.

3.2 IT Systems: All software, servers, databases, operating systems, cloud systems, and enterprise control systems used to operate and manage the company's digital infrastructure.

3.3 Sensitive Systems: Systems containing financial, health, personal, or confidential data related to clients or internal operational processes.

3.4 Sensitive Data: Data containing personal, financial, medical, or contractual information that identifies or relates to an individual or entity and requires special protection under regulatory policies.

3.5 System Environments: Development environment (DEV), User Acceptance Testing environment (UAT), Production environment (PROD), each used at different stages of the system lifecycle.

3.6 Access Point: Wireless access point enabling Wi-Fi connectivity within the facility.

3.7 CVSS (Common Vulnerability Scoring System): A global system for classifying the severity of security vulnerabilities.

3.8 DLP (Data Loss Prevention): A mechanism used to monitor sensitive data and prevent its unauthorized export from the system.

3.9 EDR (Endpoint Detection and Response): Advanced system for endpoint detection and response.

3.10 FIM (File Integrity Monitoring): A tool that monitors critical system file changes and alerts on unauthorized modifications.

3.11 IDS (Intrusion Detection System): System for detecting unauthorized activities within the network.

3.12 MFA (Multi-Factor Authentication): A security method requiring more than one verification factor before granting access.

3.13 RFC (Request for Change): An approved change request ticket used to organize and implement software or operational updates.

3.14 SIEM (Security Information and Event Management): Centralized system for analyzing and aggregating security events to assist in system monitoring and threat detection.

3.15 Tamper Protection: Feature that prevents modification or disabling of protection software on devices.

3.16 Technical Escalation: Procedure taken when a critical technical issue arises, involving raising the issue to higher management for immediate decision-making.

3.17 System Owner: The department primarily using the IT systems and responsible for operational management,

approval of proposed updates, reviewing user permissions, and coordinating with IT to ensure compliance and operational integration.

3.18 Device Register: Official database containing information on all devices used, for tracking and monitoring purposes.

3.19 Technical Incident Log: An electronic or paper log documenting all incidents related to information security or operational failures.

3.20 IT Supervisor: The employee responsible for managing the technical infrastructure, setting up networks, configuring devices, implementing technical policies, and coordinating with other departments.

3.21 Cybersecurity Officer: The employee responsible for monitoring cybersecurity controls, analyzing logs, identifying vulnerabilities, and coordinating incident response.

3.22 Least Privilege Principle: A security principle that grants users the minimum level of access necessary to perform their tasks only.

3.23 Asset Management System: An electronic system for documenting and tracking IT assets (devices, software, networks), updated regularly.

3.24 Incident Analysis Report: A document prepared by the cybersecurity officer after an incident, including cause analysis, scope of impact, and corrective recommendations.

4. Policy Scope:

4.1 This policy applies to all company IT systems, including:

4.1.1 On-premises and cloud servers.

4.1.2 Network devices.

4.1.3 Email, communication, and access systems.

4.1.4 Operational and development environments.

4.1.5 Employee devices connected to the network.

5. Relevant Departments:

5.1 IT Department.

5.2 Cybersecurity Section.

6. Related Entities:

6.1 All entities fully owned by Diamond Company.

6.2 Authorized technical suppliers.

6.3 Regulatory bodies (Insurance Authority, Cybersecurity Authority).

General Rules:

7.1 Secure System Configuration:

7.1.1 The IT specialist in the IT Department must configure all operational systems according to approved security configurations and update them periodically every 3 months.

7.1.2 All default accounts and settings must be deleted immediately after system installation, including default passwords and guest accounts.

7.1.3 All unused services and ports in the production environment must be disabled following an approved technical review.

7.1.4 Configurations must be documented in an encrypted log within the IT Asset Management System, which shall be reviewed quarterly by the Cybersecurity Officer.

7.1.5 Any deviation in configurations must be corrected by the technical team within two working days, and a follow-up report must be prepared.

7.2 Access Control:

7.2.1 The "Least Privilege" principle must be applied to all users on systems and applications.

7.2.2 The use of shared accounts or sharing login credentials among employees is strictly prohibited.

7.2.3 Multi-Factor Authentication (MFA) must be enabled on all systems containing financial, personal, or sensitive data.

7.2.4 Access permissions must be reviewed every 3 months by the Access System Manager (IT Supervisor), with the results authenticated by the system owner.

7.2.5 Excessive permissions must be removed immediately, the incident documented in the access log, and reported to the IT Supervisor.

7.3 Environment Separation:

7.3.1 Three separate environments must be established: Development (DEV), User Acceptance Testing (UAT), and Production (PROD), with real databases prohibited outside the production environment.

7.3.2 Every code transfer or upgrade between environments must be documented and approved by the Change Manager.

7.3.3 The development team is prohibited from having direct access rights to the production environment, with read-only access allowed only if necessary.

7.3.4 The separation of environments must be reviewed semi-annually.

7.4 Network and Infrastructure Security:

7.4.1 Firewall rules must be applied to minimize open ports to the absolute necessary.

7.4.2 Intrusion Detection Systems (IDS) and Security Information and Event Management (SIEM) systems must be activated and monitored 24/7 by the cybersecurity team.

7.4.3 Network diagrams must be updated and documented at least every 6 months and reviewed by the Network Manager.

7.4.4 Weak protocols (such as Telnet, FTP) are prohibited; only secure protocols like HTTPS and SSH must be used.

7.4.5 Any attempt to connect the internal network to an external network requires written permission from the Technical Management and must be recorded in the network connection log.

7.4.6 Upon detecting any unauthorized network connection attempt, the Cybersecurity Officer must issue an immediate alert, inform the IT Supervisor within one hour, document the incident in the incident log, and later present it to the Security Committee for review.

7.4.7 Connecting or using devices such as network switches or access points is prohibited without official approval and full documentation in the asset management system.

7.5 Updates and Vulnerability Management:

7.5.1 Operating systems and databases must be scanned monthly using approved tools (e.g., Nessus, Qualys).

7.5.2 Critical updates must be applied within 24 hours, medium updates within one week.

7.5.3 No update in the production environment shall be implemented without a signed change request (RFC) as per the change policy.

7.5.4 Vulnerabilities must be classified according to the CVSS framework, with specific priority and timelines assigned to each category.

7.5.5 Results of periodic scans must be reviewed in a monthly meeting, and the vulnerability register updated accordingly.

7.5.6 Penetration Testing:

7.5.6.1 Internal, external, and hosted application penetration testing must be conducted at least once a year or after any significant change in the technical environment (e.g., infrastructure upgrade or launch of a new system).

7.5.6.2 Tests must be conducted by an independent specialized entity or an accredited internal team, and results fully documented.

7.5.6.3

All exploitable vulnerabilities identified during penetration testing must be remediated within a maximum period of 30 days, and retested after remediation to verify closure.

7.5.6.4

Penetration testing reports must be stored in the vulnerability register and included in the monthly information security report.

7.5.7 Vulnerability Scanning:

7.5.7.1

Regular vulnerability scans must be conducted on internal and external networks at least once every 3 months, or immediately following any significant network change.

7.5.7.2

Approved scanning tools such as Nessus, Qualys, or equivalents must be used, covering servers, devices, and critical systems.

7.5.7.3

All vulnerabilities classified as "Critical" or "High" must be remediated within 14 days, with follow-up scans conducted until confirmed resolved.

7.5.7.4

If evidence of an actual breach or exploitation of any asset is discovered, immediate reporting to the Cybersecurity Officer and the technical support team is mandatory, with the event documented as an official security incident.

7.5.8 Security Baseline Updates:

7.5.8.1

Baseline configuration standards for all systems and servers must be updated upon discovery of new vulnerabilities affecting their settings.

7.5.8.2

The technical team is required to review and adjust outdated configurations to align with the latest cybersecurity recommendations, in coordination with the Cybersecurity Officer.

7.5.8.3

All updates to security baselines must be documented in a separate log, reviewed semi-annually.

7.5.9 Verification of Update Application:

7.5.9.1

Successful application of security updates must be verified within 5 days of installation.

7.5.9.2

Automated monitoring tools must be used to confirm completion, with verification results recorded in the update logs.

7.5.9.3

In case of update failure or unsuccessful installation, re-scheduling must occur immediately, and a follow-up report prepared by the IT team.

7.6 Malware Protection:

7.6.1

A centrally managed anti-malware solution (e.g., Kaspersky Endpoint Security or Microsoft Defender for Endpoint) must be installed on all company devices, including computers, servers, and user devices.

7.6.2

Virus definition databases must be updated automatically on a daily basis via the central protection server, and update reports reviewed weekly by the Cybersecurity Officer.

7.6.3

Users are prohibited from disabling or modifying the protection software in any way; tamper protection must be enabled to ensure this.

7.6.4

All external storage media (e.g., USB drives, DVDs) must be scanned using the approved antivirus software before use, and use is prohibited without written permission from the IT Manager.

7.6.5

Content filtering and blocking of malicious websites (e.g., DNS Filtering or Web Filtering Gateways) must be implemented, with blocklists updated automatically every 12 hours.

7.6.6

Malware scan logs for each device must be retained for no less than 6 months and reviewed monthly by the Cybersecurity Officer to identify potential threat patterns.

7.7 Log and Activity Management:

7.7.1

Comprehensive logging of all activities, including logins, modifications, failures, and escalations, must be enabled.

7.7.2

Logs must be forwarded to a centralized platform (e.g., Splunk or Wazuh) and retained for at least one year.

7.7.3

Logs must be reviewed weekly by the cybersecurity team, with reports generated on suspicious activities.

7.7.4

Change tracking tools such as File Integrity Monitoring (FIM) must be enabled on critical operating systems.

7.7.5

Any unauthorized modification attempts must be reported immediately and addressed within 24 hours.

7.8 Protection of Data During Operation, Storage, and Transmission:**7.8 Protection of Data During Operation, Storage, and Transmission:**

7.8.1

All data classified as "Confidential" must be encrypted using AES-256 in databases and file systems.

7.8.2

HTTPS must be used for internal and external websites, and SFTP for data transfers between servers.

7.8.3

Transfer of any sensitive file via email is prohibited unless encrypted using PGP or an equivalent method.

7.8.4

Classification policies must be updated every 6 months in collaboration with the Compliance Department.

7.8.5

All data transfer operations must be logged in a dedicated log that is reviewed periodically.

7.9 Secure Configuration of Endpoint Devices:

7.9.1

All USB ports must be disabled by default, with exceptions granted only through documented and approved requests from the IT Manager.

7.9.2

Device control tools must be used to monitor data input and output.

7.9.3

EDR solutions (e.g., CrowdStrike) must be activated on all devices and integrated with a centralized dashboard managed by the Cybersecurity team.

7.9.4

Each device must undergo update and reconfiguration when transferred from one user to another, following these steps:

7.9.4.1 The previous user returns the device to the IT supervisor.

7.9.4.2 The team performs a full data wipe according to secure deletion procedures.

7.9.4.3 The operating system is reinstalled, and security policies are applied.

7.9.4.4 The device is re-registered under the new user's name in the device registry.

7.9.5

This process is carried out by the IT supervisor, and all transfer or reconfiguration actions must be documented in the device registry.

7.9.6

In case of device loss, remote wiping must be performed within two hours of the report, with the action documented in the technical incident log.

7.10 Monitoring and Incident Response:

7.10.1

SIEM tools must be operated to generate automatic alerts upon detection of any unusual behavior.

7.10.2

Incidents must be managed according to a response schedule defined in the incident policy and reported within one hour.

7.10.3

Electronic evidence (logs, screenshots, reports) must be stored in a restricted-access storage unit.

7.10.4

An initial analysis report must be prepared within 48 hours and submitted to the Cybersecurity Manager and senior management.

7.10.5

Cases must be discussed monthly in the Information Security Risk meeting.

7.11 Wireless Communications Security:

7.11.1

Every access point must be registered and approved in the wireless network log.

7.11.2

WPA3 or higher must be used when available, with SSID broadcast disabled when possible.

7.11.3

Personal access points are strictly prohibited within company premises.

7.11.4

Quarterly inspections must be conducted to detect unauthorized wireless broadcasting devices (Rogue APs).

7.12 Physical Access Controls:

7.12.1

All sensitive locations must be secured with magnetic cards and video surveillance systems.

7.12.2

Visitor access must be logged, documenting identity, destination, and duration.

7.12.3

Physical access permissions must be reviewed monthly, and revoked within 24 hours of employee termination.

7.12.4

Storing any technical equipment in unsecured, open environments without locks or camera monitoring is prohibited.

7.13 Access Card Permissions:

7.13.1

Access cards are granted only with approval from the IT supervisor or Physical Security Committee.

7.13.2

Employees must sign an access and confidentiality agreement before card activation.

7.13.3

Card sharing or lending is prohibited.

7.13.4

Access rights must be revoked immediately upon resignation or transfer to another department.

7.13.5

The card registry must be reviewed quarterly to revoke unnecessary cards.

7.14 Visitor Escorting:

7.14.1

Visitors must be accompanied in all controlled areas.

7.14.2

Visitors are not allowed to move within sensitive sites without authorization and escort.

7.15 Physical Security Provisions:

7.15.1

All employees authorized for physical access to information facilities must sign access and confidentiality forms.

7.15.2

Use of access cards or keys by anyone other than the assigned holder is prohibited, as is lending or sharing.

7.15.3

Lost or stolen cards/keys must be reported immediately to the IT supervisor and revoked without delay.

7.15.4

Access rights must be reviewed quarterly, with those no longer needed revoked.

7.15.5

Reassignment of any access card to another person requires completion of official return procedures and documentation.

7.15.6

All visitors must be accompanied by an authorized employee while in protected or sensitive areas.

7.15.7

Publishing or sharing any internal maps or guides showing locations of systems or sensitive data is prohibited.

7.15.8

Measures must be taken to protect information systems from power outages or infrastructure failures, such as providing backup power sources.

7.15.9

Environmental conditions (temperature and humidity) in server rooms and sensitive facilities must be monitored to ensure compliance with safe operational requirements.

7.16 Classification and Management of Information and Its Application in Systems:

7.16.1

Systems must enforce access control rules based on the following classifications:

7.16.1.1 Public: Information requiring no special protection and may be shared publicly.

7.16.1.2 Internal: Information protected for professional or organizational reasons, shared only with authorized employees.

7.16.1.3 Confidential: Sensitive information protected legally or contractually, accessible only on a need-to-know basis.

7.16.1.4 Highly Confidential: Additional level for extremely sensitive information (e.g., client secrets or protected system data).

7.16.2

System Support for Classification:

7.16.2.1 Software or systems that do not support enforcement of classification policies are prohibited in production environments. Compliance with built-in protection standards (e.g., DLP, RBAC) is mandatory.

7.16.2.3 When any information or file classification changes, the system must automatically update protection levels based on approved security policies.

7.16.3 Documentation and Change Management:

7.16.3.1 Every classification change must be documented via an electronic log, updated automatically or manually by the system administrator, with a justified request approved by the Cybersecurity Officer.

7.16.4 Information Protection by Classification:

7.16.4.1 Internal: Stored in closed environments (locked offices or internal systems) with confidentiality agreements signed for access.

7.16.4.2 Confidential: Encrypted at rest and in transit; prohibited from being sent via unsecured channels such as unencrypted email or instant messaging.

7.16.4.3 Highly Confidential: Stored in tightly controlled environments (locked cabinets, rooms secured by magnetic cards) with strict controls including logging access, encryption, and precise permission definitions.

7.16.5 Alerting and Response:

7.16.5.1 Attempts to breach classified data must be reviewed regularly and immediately reported to the Incident Response Unit for action. Senior management must be notified in case of suspected leakage of confidential information.

7.16.6 Responsibilities:

7.16.6.1 Information User: Must use information in accordance with its classification.

7.16.6.2 Information Owner: Defines classification, approves changes, and is responsible for sharing classification with other parties.

7.16.6.3 Information Custodian: (Usually IT staff) Implements protection and encryption mechanisms per the assigned classification.

7.16.7 Retention and Disposal:

7.16.7.1 Information must be stored according to the company's approved official retention schedule.

7.16.7.2

Once the information is no longer needed, it must be classified as "Expired" and destroyed using an approved method (secure deletion / paper shredding / encrypted wiping)

7.16.7.3

No information may be destroyed without first consulting its owner to confirm that extension is not required.

7.17 Disaster Recovery and Business Continuity:

7.17.1

Diamond Insurance Brokerage must develop and implement a formal Disaster Recovery and Business Continuity Plan (DRP) aimed at ensuring the recovery of critical systems and essential data in the event of a disruption or technical/operational disaster.

7.17.2

The IT team, in coordination with the Information Security Committee, is responsible for updating and documenting the recovery plan at least annually, conducting periodic tests, and analyzing test results to implement corrective and improvement actions promptly.

7.17.3

At a minimum, the recovery plan must include

7.17.3.1 Business Impact Analysis (BIA), including risk assessment and classification of technical assets based on sensitivity and operational importance.

7.17.3.2 Clear identification of critical systems and essential information requiring immediate recovery.

7.17.3.3 Preventive strategies, including UPS systems, fire protection, power fluctuation protection, and environmental controls (temperature, humidity, dust).

7.17.3.4 Regular backup procedures with secure storage in multiple offsite locations.

7.17.3.5 A Contingency Plan outlining mechanisms for restoring systems and data during downtime.

7.17.3.6 Definition of organizational responsibilities for each department and team during disaster stages (response – recovery – phased operation).

7.17.3.7 Clear escalation procedures for reporting catastrophic incidents, activating the recovery plan, and tracking execution until full stability.

7.17.

The plan must include periodic training programs for all relevant personnel and conduct live simulations to test team readiness. The results of these simulations must be documented and included in the annual improvement reports.

7.17.5

All relevant employees and technical vendors are obligated to execute the recovery instructions immediately upon declaration of a disaster, fully adhering to the defined procedures without delay or individual discretion.

7.17.6

Improvised actions or the activation of any affected critical system is strictly prohibited before reviewing the approved recovery plan and obtaining permission from the IT Supervisor or the Information Security Officer.

7.17.7

An up-to-date copy of the recovery plan must be stored in at least two separate locations (digital and physical) and made available to relevant parties when needed, while ensuring confidentiality and restricting external sharing.

7.17.8

Any violation of this policy—such as delayed response, failure to execute defined procedures, or negligence in plan updates—is considered a serious offense and may result in disciplinary action, including termination or legal consequences.

7.18 Policy Development and Approval Lifecycle for IT Security:

7.18.1

The IT Security Policy must follow a clear development lifecycle that includes:

Development → Review → Approval → Implementation → Continuous Evaluation,
to ensure alignment with business needs and regulatory changes.

7.18.2

The IT team is required to document each stage in the security policy lifecycle, specifying the responsible party and the date.

7.19 Oversight by the Cybersecurity Committee:

7.19.1

The policy must be presented to the DIB Information Security Committee for review and to ensure its alignment with the organization's comprehensive information security program.

7.19.2

The Cybersecurity Officer is responsible for submitting any major updates to the committee, and the policy will not be approved without documented consent from the committee.

7.19.3

All approved policy meeting minutes must be stored in the official records of the IT Department.

7.20 Policy Publishing and Employee Awareness:

7.20.1

The IT Department must publish the final approved version of this policy on the official internal employee portal.

7.20.2

Every employee with access rights to IT systems must sign an acknowledgment of having read the policy and agreeing to comply with its provisions.

7.20.3

The Cybersecurity Department shall organize awareness sessions at least annually to educate employees on the policy's provisions and best practices.

7.21 Compliance Measurement and Review:

7.21.1

The Cybersecurity Officer must conduct monthly compliance reviews, including log analysis, permission audits, and verification of control implementations.

7.21.2

Information security compliance assessment reports must be prepared quarterly and submitted to senior management and the Cybersecurity Committee with corrective recommendations.

7.21.3

All departments owning a technical system are required to fully cooperate with audits and provide necessary documentation and support upon request.

8. Policy Responsibilities:

8.1 IT Department:

Responsible for implementing security configurations, managing networks, and closing operational vulnerabilities.

8.2 Cybersecurity Department:

Responsible for log analysis, access monitoring, vulnerability scanning, and incident response.

8.3 System Owner Departments:

Responsible for reporting security issues and cooperating in implementing protection measures.

8.4 Quality and Development Department:

Responsible for ensuring these policies are implemented through audits and periodic reviews.

9. Related Circulars and Directives:

9.1

As per the Technical Specifications Circular for CCTV Systems, issued by the Saudi Central Bank (SAMA), Ref. (202010/197), dated 2020/10/27.

9.2

regarding the use of digital surveillance systems for secure transmission and storage of CCTV device recordings and data, issued by SAMA, Ref. (202110/224), dated 2021/10/24.

9.3

The Organizational Guide for Information Security, issued by SAMA, Ref. (202205/250), dated 2022/05/26.

10.1 A non-copyable electronic version of the approved policy shall be stored in the Human Resources system, and made accessible to relevant departments.

10.2 A hard copy of the approved policy shall be retained by the Quality and Development Department for the statutory retention period specified in the Document Retention Manual, and shall then be transferred to the official document archiving system.

11. Policy Violations:

11.1 Any violation of this policy shall be subject to the disciplinary actions outlined in the approved Diamond Company Sanctions Regulation.